

**Oppgave til skriftlig eksamen i SKY2100 – Skysikkerhet
ved Høyskolen Kristiania.
Høsten 2024**

1. Oversikt over eksamen og formelle krav

Utlevering av eksamensoppgave: 29.11.2024 kl. 10:00

Frist for innlevering: 06.12.2024 kl. 10:00

Faglig kontakt under eksamen: Timo Amling, timo.amling@kristiania.no

Eksamensform: Skriftlig individuell hjemmeeksamen

Format på besvarelsen: A4-format, enten LaTeX- eller Word-format med størrelse 11 og linjeavstand 1,0 i skrifttypen Arial. Maksimalt 12 sider. Dette inkluderer tekst, skjermdumper og andre figurer og tabeller. Litteraturlisten kan komme i tillegg til dette. Du kan sende inn besvarelsen som .docx- eller PDF-fil. **Viktig:** Når du sender inn besvarelsen, setter du inn språket på slutten av filnavnet, skilt ut med «_» (f.eks. «Candidate001_English.docx» eller «Candidate001_Norsk.pdf»)

Hjelpemidler: Alle hjelpemidler er tillatt – herunder pensumbøker, lysbilder og praktiske oppgaver fra kurset.

Karakterskala: Det norske karaktersystemet bruker karakterskalaen A–F, der A er beste karakter, E er laveste beståtte karakter, og F er ikke bestått.

Vekting: 100 % av totalkarakteren

Plagiatkontroll: Vi forventer at du leverer et selvstendig arbeid. Bruk henvisninger og sitater hvis det er materiale du ønsker å inkludere i besvarelsen. Dette omfatter tekst og annet materiale, f.eks. figurer og tabeller. Bruk APA7 til å referere fra forelesningsmaterieell. Du skal kun bruke henvisninger i teksten. Det betyr at du skal vise til det eksakte stedet i en setning når du siterer eller henter informasjon fra en kilde. Informasjon: Når det gjelder henvisning til bøker, skal du vise til siden(e). Når det gjelder lysbilder, skal du vise til forelesningen (1–12) og nummeret på lysbildet (tallet nederst til høyre på bildet, ikke sidenummeret som vises i PDF-leseren).

Oppgaveformat: Det er obligatorisk å besvare oppgave A. Deretter kan du velge praktisk oppgave B **ELLER** svare på oppgave C, i tilfelle PC-en din har problemer med virtualiseringen. Hvis du velger oppgave C, må du også ta med en skjermdump av feilen eller systemmeldingen (tid og data skal være synlige på skjermdumpen) som viser at du ikke kan utføre virtualiseringsoppgaven.

Skjermdumper: Det er obligatorisk å ha med «kandidatnummeret» ditt på skjermdumpene med tanke på dokumentasjon. Det kan du gjøre ved f.eks. å endre brukernavnet ditt for den virtuelle maskinen til kandidatnummeret ditt. Alternativt kan du åpne et redigeringsprogram med kandidatnummeret ditt og inkludere det i skjermbildet når du tar skjermdumper. Du skal bare oppgi skjermbilder det er bedt om i oppgavene.

Læringsutbytte i henhold til emnebeskrivelsen:

Kunnskap. Studenten ...

- kan definere og forklare hvordan skytjenester fungerer
- kan forklare begrepene Software as a Service, Platform as a Service og Security as a Service
- kan definere og forklare hvordan skyløsninger sikres og hvilke forskjeller og likheter dette er i forhold til interne servere
- kan forklare forskjellen på en Cloud Native-applikasjon og en skymigrasjon som benytter Lift And Shift-metodikk
- kan definere og forklare rollen til en Web Application Firewall og hvordan en WAF kan inngå i sikkerhetsarkitektur

- kan definere og forklare utviklingsmetodikken DevSecOps og hvordan dette skiller seg fra tradisjonell produktutvikling

Ferdigheter. Studenten ...

- kan bruke, konfigurere og administrere sikkerhet i en skyløsning
- kan installere og konfigurere en Web Application Firewall og bruke denne for å beskytte en skyløsning
- kan bruke verktøy for sikkerhets- og sårbarhetsanalyse som er integrert i skyløsningen
- kan bruke integrert logging i skyløsninger og forstå hvordan disse loggene kan integreres med et SIEM-verktøy

Generell kompetanse. Studenten ...

- kan reflektere arkitekturkravene og gi råd om sikkerhetsarkitektur og implementering av sikkerhetsløsninger i skytjenester
- kan beskrive og definere fordeler og ulemper ved etablering eller flytting av prosjekt / tjeneste til skyen fra et sikkerhetsperspektiv

2. Eksamensoppgave

Oppgave A (70 % av vurderingen)

Etter eksamen fra Kristiania blir du ansatt som junior skyarkitekt i et IT-konsulentselskap i Osloregionen. Fokuset til dette selskapet er å tilby IoT-tjenester over Microsoft Azure til kunder. Selskapet har i dag over 400 ansatte. De fleste av disse er utviklere og programvarearkitekter. I tillegg til hovedkontoret i Oslo har selskapet også kontorer i Stockholm, Berlin, Madrid og Paris, men deres Azure-tenant befinner seg i Amsterdam i Microsofts datasenter (distribusjonsmodell: privat sky). De har stort sett småskalaprojekter som kun krever en liten mengde IoT-data over VPN. Økt etterspørsel i markedet gjør at selskapet forventer å vokse og utvide virksomheten til USA og Tyskland. I USA vil det bli etablert fire nye kontorer neste år i Atlanta (Georgia), New York City (New York) og Los Angeles (California), med ytterligere 2 000 ansatte. I Tyskland kommer det til å komme ytterligere 1 000 ansatte i Berlin, Frankfurt og Hamburg. Azure-tjenesten må derfor spres over flere steder i og utenfor EU for å sikre tilgjengelighet og robusthet døgnet rundt i forretningsmodellen. På denne måten utvider IT-konsulentfirmaet også forretningsmodellen og fokuserer nå på å jobbe med store mengder salgbare høytytende analyser av IoT-data (f.eks. sensorer), flere standardiserings- og styringsmekanismer samt applikasjonsutvikling for utviklere og programvarearkitekter.

- **Oppgave A.1:** Bruk de viktigste pensumbøkene og referanser i teksten for å forklare hvilken tjeneste- og distribusjonsmodell du vil anbefale for fremtiden. Hvilke avveininger kan du se for deg i dette scenariet basert på pensumbøkene og lysbildene våre.
- **Oppgave A.2:** Beskriv forskrifter fra de viktigste pensumbøkene og tilknyttede Azure-kilder som kan ha gyldighet for en utvidelse til fremtidige regioner. Gi også 3–5 anbefalinger med tanke på å sikre etterlevelse av IT-regelverk (juridiske IT-problemstillinger knyttet til IT) når du utvider, basert på pensumbøkene og lysbildene våre.
- **Oppgave A.3:** Tenk deg at du skal lage en skreddersydd opplæring i IT-sikkerhet for nyansatte utviklere og programvarearkitekter. Denne opplæringen skal omfatte mønsterpraksis for livssyklusen i utviklingen av sikkerhetsprogramvare. Skriv ned hvilke trinn du vil anbefale. Svar også på hvilket rammeverk du vil anbefale, og begrunn valget, i dette spesifikke scenariet basert på pensumbøkene og lysbildene våre.
- **Oppgave A.4:** Når det formelle regelverket er klart og personellet er lært opp, kan utvidelsen av skyen begynne. Som et av de første trinnene ber selskapet deg om å opprette en sikkerhetsplan, som omfatter en risikovurdering. Derfor bruker du kjerneelementene i NIST CSF. Gå gjennom hvert av elementene og beskriv hvordan du ville utfordret dem i dette scenariet. Når det gjelder risikovurderingen, fokuserer du på kontinuiteten i virksomheten og gjenopprettingen i tilfelle en katastrofe. Hvilken anbefaling ville du kommet med her basert på pensumbøkene og lysbildene våre.
- **Oppgave A.5:** Ta med skjermdump av de fullførte opplæringsmodulene i Azur <https://learn.microsoft.com/en-us/users/> ved å klikke på «Training». Du kan endre brukernavnet ditt av anonymiseringsgrunner ved å følge <https://learn.microsoft.com/en-us/users/me/settings>, der du om nødvendig kan endre «Display name» og eventuelt «Username and URL».

Viktig: Bruk informasjon fra lysbildene og pensumbøkene i alle oppgavene. Vis til lysbildet/siden der du har funnet informasjon om løsningsforslaget ditt i henhold til de formelle kravene som er nevnt på første side av eksamensoppgaven.

Oppgave B (30 % av vurderingen)

- **Oppgave B.1:** Installer Ubuntu Virtual Machine enten i VMware eller VirtualBox.
- **Oppgave B.2:** På kommandolinjen går du inn på informasjon om a) antall CPU/kjerner og bogomips per kjerne, b) åpner nettverksporten og forklarer utdataene. Hva ser du og hvor kan du identifisere svarene i terminalens utdata? **Viktig:** Ta en skjermdump av resultatene fra a) og b) som også viser kandidatnummeret ditt (f.eks. ved å åpne et redigeringsprogram ved siden av terminalen din og skrive inn kandidatnummeret).
- **Oppgave B.3:** Installer Nginx-serveren i din VM. Åpne to terminalvinduer, og utfør en simulering av DDoS-angrepet: «`ab -n 100000 -c 100 127.0.0.1`» i ett av dem. I det andre kjører du den interaktive «*htop*»-kommandoen. Hva var den høyeste CPU-belastningen du klarte å oppnå? Gi en kort forklaring. **Viktig:** Ta med skjermdumpen i rapporten som viser DDoS-angrepet og «*htop*»-kommandoen. Skjermdumpen må vise kandidatnummeret ditt (f.eks. ved å åpne et redigeringsprogram ved siden av terminalen din og skrive inn kandidatnummeret).
- **Oppgave B.4:** Installer docker og kjør samme forsøk i docker-beholderen med Nginx. **Viktig:** Ta med en skjermdump i rapporten som viser docker-installasjonen, testresultatene og systembelastningen, og se om det er noen forskjeller sammenlignet med resultatene fra (B.3). Skjermdumpen må vise kandidatnummeret ditt.
- **Oppgave B.5:** Analyser gjennomsnittlig antall forespørsler/samtidighets-tråder som VM-maskinen kan håndtere før den går offline («DDoS») på grunn av for mange forespørsler. Sjekk om din VM kan holde én million forespørsler mot webserveren: «`ab -n 1000000 -c 1000 127.0.0.1`». Hva er resultatet? Gi en kort forklaring.

Oppgave C (30 % av vurderingen)

Et stort regnskapsselskap ønsker å etablere en ny skybasert samarbeidsplattform. Selskapet holder til i USA, men de har kontorer over hele verden. De har mer enn 150 000 ansatte, hvorav 10 000 i Norge. Alle de lokale kontorene er underlagt hovedkontoret i USA. Det betyr at det norske kontoret i Oslo må følge de interne retningslinjene fra det amerikanske hovedkontoret, men også overholde norsk og EU-lovgivning. Selskapet håndterer uansett en stor mengde sensitive data fra kundene, herunder tall som viser økonomiske resultater i mange forskjellige formater og størrelser. Den nye samarbeidsplattformen skal styrke tilliten mellom regnskapsselskapet og kundene deres, og gi kunden tilgang til plattformen. Her kan kundene laste opp enorme mengder ustrukturerte data og få et inntrykk av funn og fremdrift i IT-revisjonen. Når dette er sagt, er det ikke bare én kunde, men mange som trenger tilgang samtidig, men personvern og IT-sikkerhet anses som viktige faktorer og avgjørende for at plattformen skal lykkes.

- **Oppgave C.1:** Du jobber som IT-konsulent for dette regnskapsselskapet, og oppgaven din er å planlegge en slik plattform. Beskriv infrastrukturen og plattformstrukturen i detalj, herunder personvern, IT-sikkerhet og etterlevelse av IT-regelverk. Vurder også økonomiske faktorer for å flytte til en skytjeneste og beskyttelsesmekanismene for cybersikkerhet som du kjenner fra forelesningene. Trenger du mekanismer som IAM, kryptering eller DDoS-beskyttelse? Forklar hvorfor basert på de viktigste pensumbøkene og lysbildene våre.

Viktig: Du skal kun bruke informasjon fra lysbildene og pensumbøkene. Vis til lysbildet/siden der du har funnet informasjon om løsningsforslaget. Du kan også gjøre antagelser som at visse sertifiseringer og samsvarsrapporter for IT-sikkerhet/sky/etterlevelse enten er på plass, eller at det er behov for slike, basert på pensumbøkene og lysbildene våre.